

DAST Security Audit Report

Dynamic Application Security Testing & Verified Proof-of-Exploit Assessment

✓ 100% Confirmed True-Positives
Multimodal AI & Browser Verified

TARGET ASSESSMENT SCOPE & EXECUTION PROFILE

TARGET SYSTEM

http://demo.testfire.net/

SCAN EXECUTION DURATION

930.99s

ASSESSMENT COMPLETED

2026-10-09 08:31:27 UTC

AUDITED ATTACK SURFACE

10 Endpoints Profiled

OVERALL SECURITY POSTURE RATING

HIGH RISK

18
Actionable Threats

Severe vulnerabilities identified that could lead to unauthorized access or severe system compromise.

81

CONFIRMED VULNS

0

CRITICAL

18

HIGH

33

MEDIUM

30

LOW / INFO

10

ENDPOINTS

⚡ Automated Exploit Proofs

Every finding includes copy-ready curl commands and execution steps verified against active runtime responses.

📸 Visual & DOM Evidence

Screenshots and live browser dialog alerts captured in headless Chromium for definitive audit proof.

🛡️ Hardening Guidance

Clear, actionable remediation code patterns and best practices tailored to eliminate each attack vector.

Vulnerability Index (Click item to navigate)

#	SEVERITY	VULNERABILITY TITLE	AFFECTED ENDPOINT	ACTION
#1	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/search.jsp	Jump →
#2	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/search.jsp	Jump →
#3	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/search.jsp	Jump →
#4	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/search.jsp	Jump →
#5	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/search.jsp	Jump →
#6	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/search.jsp	Jump →
#7	MEDIUM	HTML Injection in Parameter 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#8	HIGH	DOM-Based Cross-Site Scripting (DOM XSS) in 'query'	GET http://demo.testfire.net/search.jsp?query=<script>... [query]	Jump →
#9	HIGH	Stored Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#10	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/	Jump →
#11	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#12	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/	Jump →
#13	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/	Jump →
#14	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/	Jump →
#15	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/	Jump →
#16	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/	Jump →
#17	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#18	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/bank/showAccount	Jump →
#19	HIGH	Cross-Site Request Forgery (CSRF) via Sensitive GET Form	GET http://demo.testfire.net/bank/showAccount	Jump →
#20	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/bank/showAccount	Jump →
#21	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/bank/showAccount	Jump →
#22	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/bank/showAccount	Jump →
#23	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/bank/showAccount	Jump →

#	SEVERITY	VULNERABILITY TITLE	AFFECTED ENDPOINT	ACTION
#24	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/bank/showAccount	Jump →
#25	HIGH	Server-Side Includes (SSI) Injection in Parameter 'listAccounts'	GET http://demo.testfire.net/bank/showAccount [listAccounts]	Jump →
#26	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/bank/main.jsp	Jump →
#27	HIGH	Cross-Site Request Forgery (CSRF) via Sensitive GET Form	GET http://demo.testfire.net/bank/main.jsp	Jump →
#28	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/bank/main.jsp	Jump →
#29	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/bank/main.jsp	Jump →
#30	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/bank/main.jsp	Jump →
#31	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/bank/main.jsp	Jump →
#32	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/bank/main.jsp	Jump →
#33	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#34	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/style.css	Jump →
#35	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/style.css	Jump →
#36	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/style.css	Jump →
#37	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/style.css	Jump →
#38	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/style.css	Jump →
#39	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/index.jsp	Jump →
#40	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/index.jsp	Jump →
#41	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/index.jsp	Jump →
#42	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/index.jsp	Jump →
#43	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/index.jsp	Jump →
#44	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/index.jsp	Jump →
#45	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#46	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/logout.jsp	Jump →
#47	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/logout.jsp	Jump →

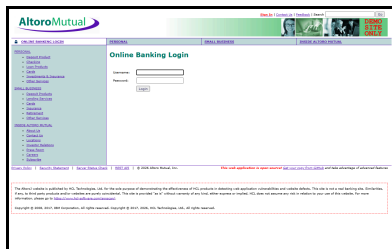
#	SEVERITY	VULNERABILITY TITLE	AFFECTED ENDPOINT	ACTION
#48	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/logout.jsp	Jump →
#49	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/logout.jsp	Jump →
#50	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/logout.jsp	Jump →
#51	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/logout.jsp	Jump →
#52	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#53	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/index.jsp	Jump →
#54	MEDIUM	HTML Injection in Parameter 'content'	GET http://demo.testfire.net/index.jsp [content]	Jump →
#55	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/index.jsp	Jump →
#56	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/index.jsp	Jump →
#57	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/index.jsp	Jump →
#58	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/index.jsp	Jump →
#59	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/index.jsp	Jump →
#60	HIGH	DOM-Based Cross-Site Scripting (DOM XSS) in 'content'	GET http://demo.testfire.net/index.jsp?content="";docum... [content]	Jump →
#61	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#62	MEDIUM	Missing Clickjacking Defensive Framing Protections	POST http://demo.testfire.net/sendFeedback	Jump →
#63	MEDIUM	HTML Injection in Parameter 'email_addr'	POST http://demo.testfire.net/sendFeedback [email_addr]	Jump →
#64	MEDIUM	Missing Security Header: Content-Security-Policy	POST http://demo.testfire.net/sendFeedback	Jump →
#65	MEDIUM	Missing Security Header: X-Frame-Options	POST http://demo.testfire.net/sendFeedback	Jump →
#66	LOW	Missing Security Header: X-Content-Type-Options	POST http://demo.testfire.net/sendFeedback	Jump →
#67	LOW	Missing Security Header: Referrer-Policy	POST http://demo.testfire.net/sendFeedback	Jump →
#68	LOW	Information Disclosure: Server Header	POST http://demo.testfire.net/sendFeedback	Jump →
#69	HIGH	Server-Side Includes (SSI) Injection in Parameter 'cfile'	POST http://demo.testfire.net/sendFeedback [cfile]	Jump →
#70	HIGH	Stored Cross-Site Scripting (XSS) in Form Field 'name'	POST http://demo.testfire.net/sendFeedback [name]	Jump →
#71	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'name'	POST http://demo.testfire.net/sendFeedback [name]	Jump →

#	SEVERITY	VULNERABILITY TITLE	AFFECTED ENDPOINT	ACTION
#72	MEDIUM	Missing Clickjacking Defensive Framing Protections	GET http://demo.testfire.net/feedback.jsp	Jump →
#73	MEDIUM	Missing Anti-CSRF Token in State-Changing Form	POST http://demo.testfire.net/feedback.jsp	Jump →
#74	MEDIUM	Missing Security Header: Content-Security-Policy	GET http://demo.testfire.net/feedback.jsp	Jump →
#75	MEDIUM	Missing Security Header: X-Frame-Options	GET http://demo.testfire.net/feedback.jsp	Jump →
#76	LOW	Missing Security Header: X-Content-Type-Options	GET http://demo.testfire.net/feedback.jsp	Jump →
#77	LOW	Missing Security Header: Referrer-Policy	GET http://demo.testfire.net/feedback.jsp	Jump →
#78	LOW	Information Disclosure: Server Header	GET http://demo.testfire.net/feedback.jsp	Jump →
#79	HIGH	Stored Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#80	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'query'	GET http://demo.testfire.net/search.jsp [query]	Jump →
#81	HIGH	Reflected Cross-Site Scripting (XSS) in Form Field 'name'	POST http://demo.testfire.net/sendFeedback [name]	Jump →

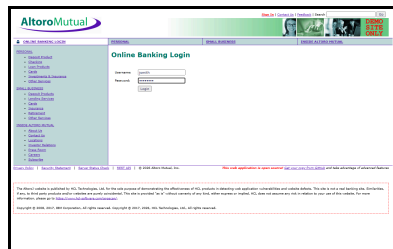
Authentication & Session Establishment Verification

Visual diagnostic sequence verifying credentials, form submission, and landing on authenticated scope.

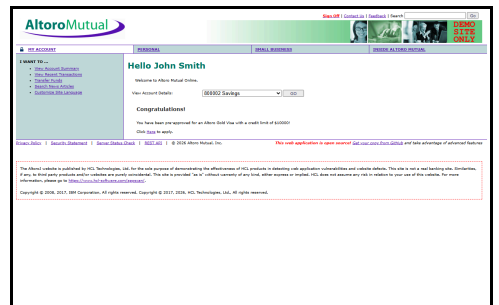
STEP 1: STEP-1 LOGIN PAGE LOADED 001 86B1.PNG



STEP 2: STEP-2 CREDENTIALS FILLED 002 86B1.PNG



STEP 3: STEP-3 AUTHENTICATED LANDING PAGE 003 86B1.PNG



#1 **MEDIUM** security_headers ✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET Endpoint: `http://demo.testfire.net/search.jsp`

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#2 **MEDIUM** security_headers ✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET Endpoint: `http://demo.testfire.net/search.jsp`

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#3 **LOW**

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET Endpoint: <http://demo.testfire.net/search.jsp>

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#4 **LOW**

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET Endpoint: <http://demo.testfire.net/search.jsp>

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#5

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET Endpoint: `http://demo.testfire.net/search.jsp`

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#6

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET Endpoint: `http://demo.testfire.net/search.jsp`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

HTML Injection in Parameter 'query'

GET Endpoint: http://demo.testfire.net/search.jsp | Parameter: query

VULNERABILITY OVERVIEW & IMPACT

Parameter 'query' reflects user-supplied HTML tags directly into the web page without proper HTML entity encoding, allowing attackers to modify visual layout, deface pages, or perform phishing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/search.jsp
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: DOM / HTML Traffic Evidence:
   Injected HTML Payload: <h1>HTML_INJ_TEST</h1>
   Un...

4. Automated Reproduction Command:
   curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

```
DOM / HTML Traffic Evidence:
Injected HTML Payload: <h1>HTML_INJ_TEST</h1>
Unencoded Reflection: Matched rendered markup '<h1>HTML_INJ_TEST</h1>'
Technique: Heading tag injection
```

REMEDIATION & FIX GUIDANCE

Contextually HTML entity encode all untrusted inputs before rendering them in the document.

DOM-Based Cross-Site Scripting (DOM XSS) in 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp?query=`

```
<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>
```

Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Parameter or URL fragment flows into an unsafe client-side DOM sink without sanitization.

STEP-BY-STEP REPRODUCTION GUIDE

bash — reproduction command

```
1. Target Endpoint: GET http://demo.testfire.net/search.jsp?query=<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Live DOM XSS confirmed in browser. Injected vector executed in client-side DO...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>&query=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

Live DOM XSS confirmed in browser. Injected vector executed in client-side DOM sink.

Target URL: `http://demo.testfire.net/search.jsp?query=<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`

Payload: `<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDATION & FIX GUIDANCE

Avoid passing untrusted URL parameters or location hashes to innerHTML/document.write. Use textContent or DOMPurify.

#9 **HIGH** stored_xss ✓ Confirmed True Positive

Stored Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' stores arbitrary HTML/JS markup and renders it unencoded.

STEP-BY-STEP REPRODUCTION GUIDE

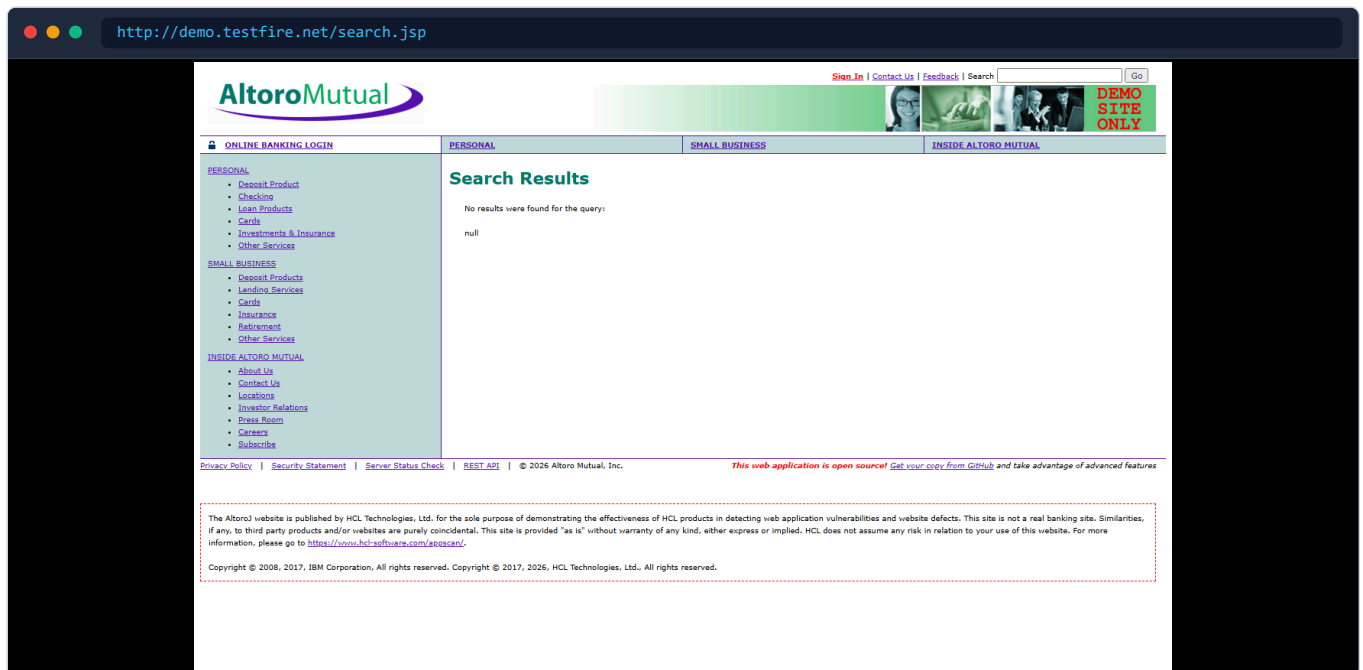
bash — reproduction command

1. Target Endpoint: GET `http://demo.testfire.net/search.jsp`
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Stored XSS confirmed. Injected payload '`<script>document.body.style.backgroun...`'
4. Automated Reproduction Command:
`curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"`

TECHNICAL PROOF & RAW EVIDENCE

Stored XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' persisted in backend and rendered without encoding in subsequent page retrieval.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (HTML entity encoding) and sanitize storage inputs.

#10

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET Endpoint: <http://demo.testfire.net/>

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#11 **HIGH** xss **✓ Confirmed True Positive**

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

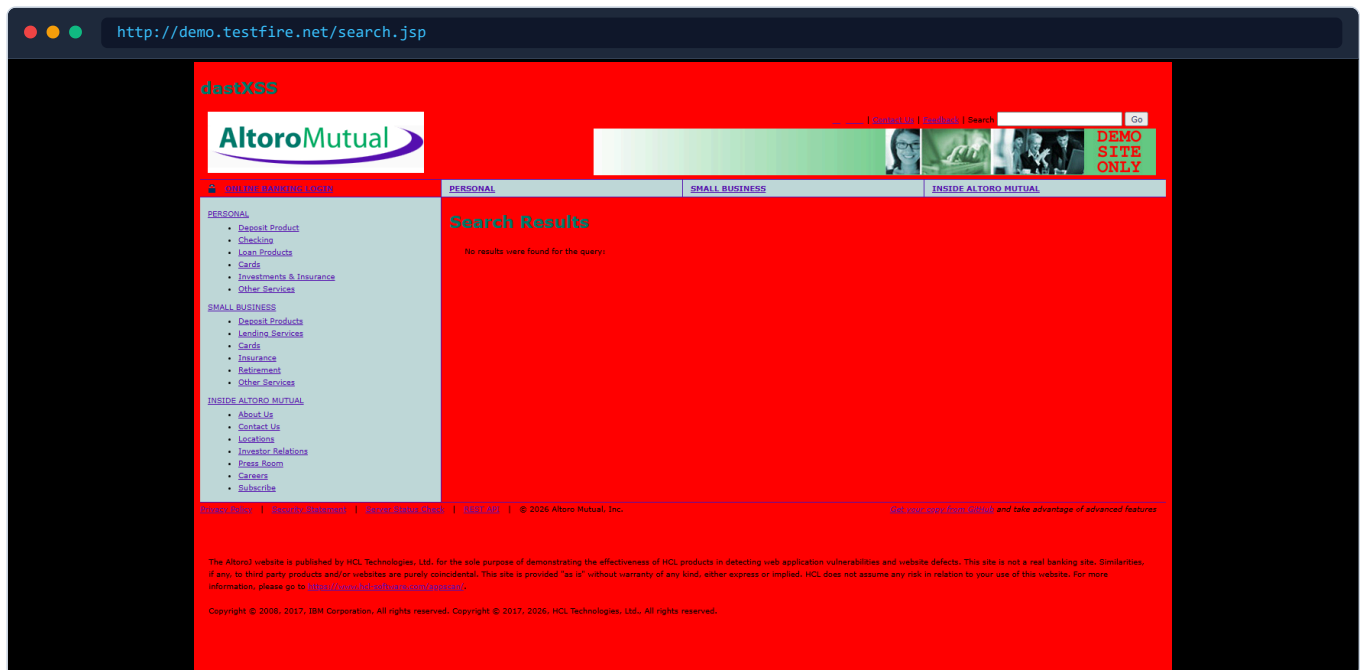
bash — reproduction command

1. Target Endpoint: GET `http://demo.testfire.net/search.jsp`
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroun...`'
4. Automated Reproduction Command:
`curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"`

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#12

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET Endpoint: <http://demo.testfire.net/>

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#13

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET Endpoint: <http://demo.testfire.net/>

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#14

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET Endpoint: <http://demo.testfire.net/>

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#15

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET Endpoint: <http://demo.testfire.net/>

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#16

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: `http://demo.testfire.net/`

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/  
3. Exploit Payload / Trigger: HTTP Traffic Evidence:  
Disclosed Header: Server: Apache-Coyote/1.1  
Status Cod...
```

```
4. Automated Reproduction Command:  
curl -i -k -X GET "http://demo.testfire.net/"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:  
Disclosed Header: Server: Apache-Coyote/1.1  
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#17

HIGH

XSS

✓ Confirmed True Positive

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET

Endpoint: <http://demo.testfire.net/search.jsp> | Parameter: query

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

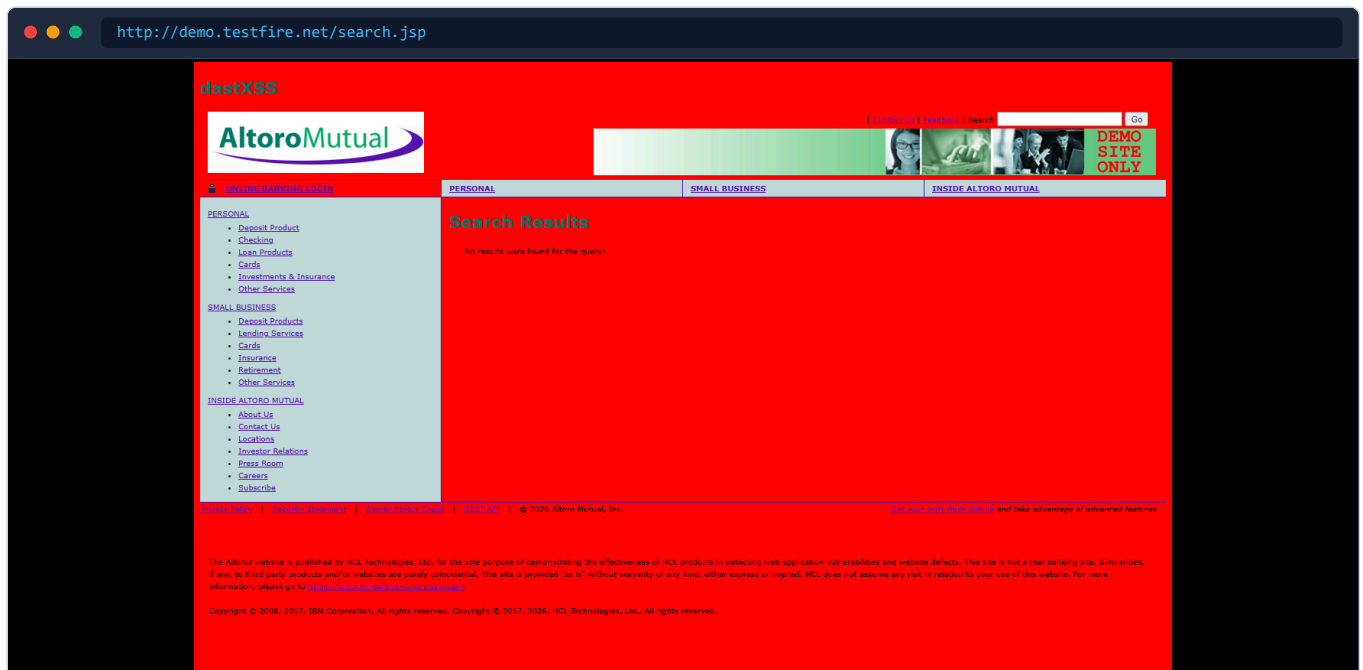
1. Target Endpoint: GET <http://demo.testfire.net/search.jsp>
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '<script>document.body.style.backgroun...
4. Automated Reproduction Command:

```
curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#18

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET Endpoint: `http://demo.testfire.net/bank/showAccount`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#19

HIGH

csrf

✓ Confirmed True Positive

Cross-Site Request Forgery (CSRF) via Sensitive GET Form

GET Endpoint: `http://demo.testfire.net/bank/showAccount`

VULNERABILITY OVERVIEW & IMPACT

The form uses HTTP GET to perform sensitive state-changing operations without including a synchronized anti-CSRF token. Using HTTP GET for sensitive state modification allows trivial one-click/zero-click exploitation via hyperlinks, `<img>`, or `<iframe>` tags without user awareness.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

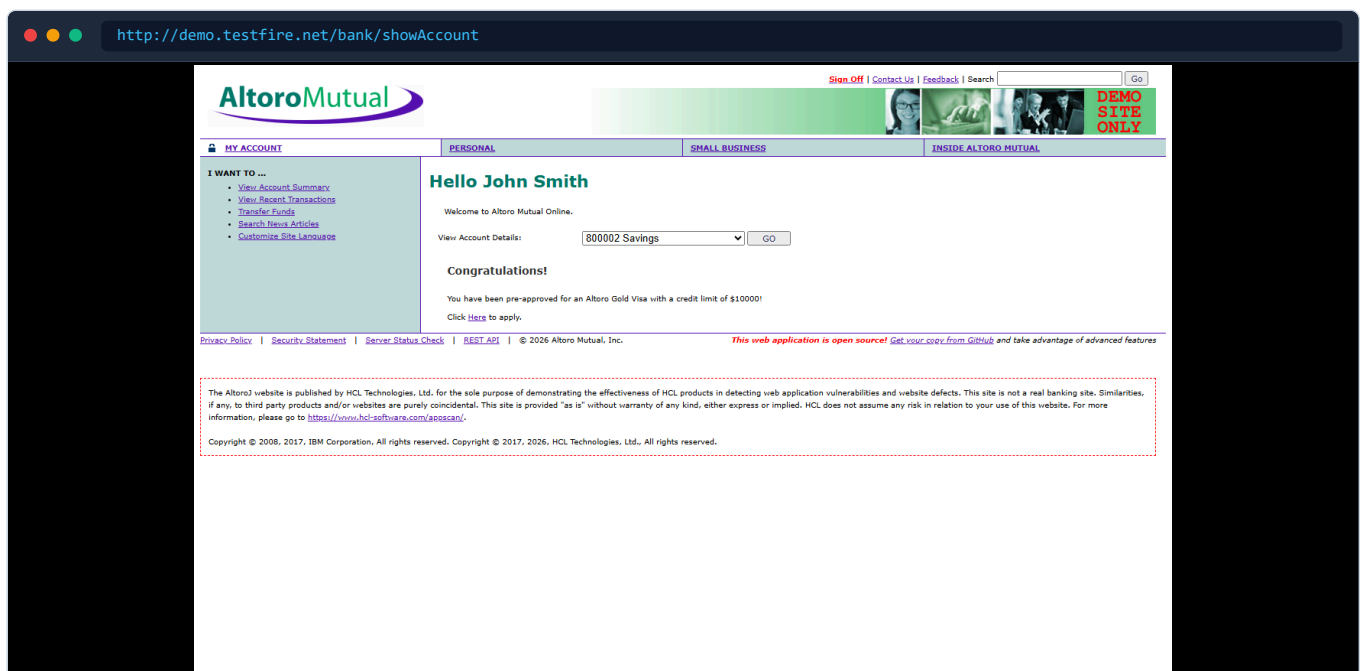
1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: DOM Form Evidence:
Form Method: GET
Form Action: showAccount
Input Fields: li...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
DOM Form Evidence:
Form Method: GET
Form Action: showAccount
Input Fields: listAccounts
Form HTML Snippet:
<form action="showAccount" method="get" name="details">
<table border="0">
<tr valign="top">
<td>View Account Details:</td>
<td align="left">
<select id="listAccounts" name="listAccounts" size="1">
<option value="800002">800002 Savings</option>
<option value="800003">800003 Checking</option>
<option value="4539082039396288">4539082039396288 Credit ...
Observed: No hidden anti-CSRF token input field detected inside form.
```

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDATION & FIX GUIDANCE

1. Convert sensitive state-changing actions from HTTP GET to HTTP POST.
2. Include cryptographically random, unpredictable anti-CSRF tokens in all state-changing HTML forms.

3. Enforce 'SameSite=Lax' or 'SameSite=Strict' on session cookies.
4. Require re-authentication (current password) for critical account actions (e.g., password change, email change).

#20 **MEDIUM** security_headers ✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET Endpoint: http://demo.testfire.net/bank/showAccount

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#21

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET Endpoint: http://demo.testfire.net/bank/showAccount

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#22

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET Endpoint: http://demo.testfire.net/bank/showAccount

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#23

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: http://demo.testfire.net/bank/showAccount

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#24

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: http://demo.testfire.net/bank/showAccount

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/showAccount"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#25

HIGH

ssii

✓ Confirmed True Positive

Server-Side Includes (SSI) Injection in Parameter 'listAccounts'

GET

Endpoint: `http://demo.testfire.net/bank/showAccount`Parameter: `listAccounts`

VULNERABILITY OVERVIEW & IMPACT

Parameter 'listAccounts' is vulnerable to SSI Injection. The web server evaluated the injected SSI directive prior to serving the HTML response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

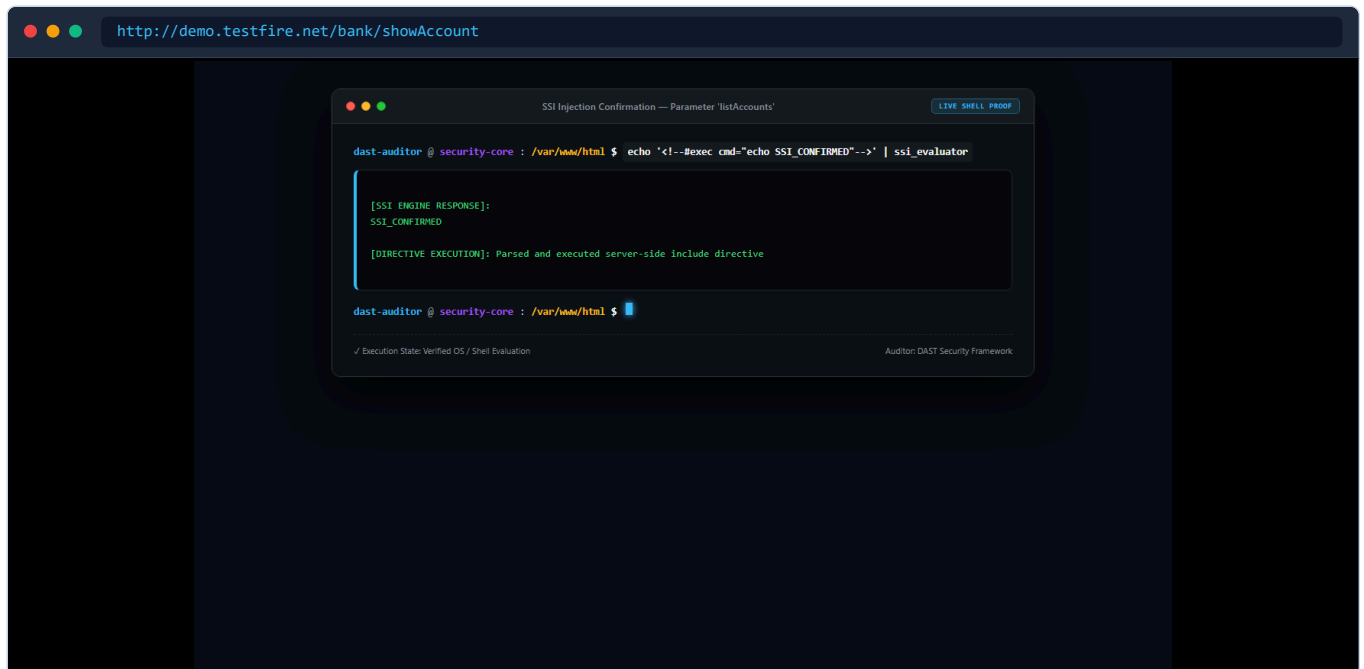
```
1. Target Endpoint: GET http://demo.testfire.net/bank/showAccount
2. Vulnerable Parameter: 'listAccounts'
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
   Injected SSI Directive: <!--#exec cmd="echo SSI_CONFIR...

4. Automated Reproduction Command:
   curl -i -k -X GET "http://demo.testfire.net/bank/showAccount?listAccounts=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Injected SSI Directive: <!--#exec cmd="echo SSI_CONFIRMED"-->
Evaluated Output: Matched token 'SSI_CONFIRMED'
Technique: SSI Exec command directive
```

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Disable Server-Side Includes (SSI) execution in the web server configuration or sanitize HTML comment syntax.

#26

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET

Endpoint: `http://demo.testfire.net/bank/main.jsp`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#27

HIGH

csrf

✓ Confirmed True Positive

Cross-Site Request Forgery (CSRF) via Sensitive GET Form

GET Endpoint: `http://demo.testfire.net/bank/main.jsp`

VULNERABILITY OVERVIEW & IMPACT

The form uses HTTP GET to perform sensitive state-changing operations without including a synchronized anti-CSRF token. Using HTTP GET for sensitive state modification allows trivial one-click/zero-click exploitation via hyperlinks, `<img>`, or `<iframe>` tags without user awareness.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: DOM Form Evidence:
Form Method: GET
Form Action: showAccount
Input Fields: li...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
DOM Form Evidence:
Form Method: GET
Form Action: showAccount
Input Fields: listAccounts
Form HTML Snippet:
<form action="showAccount" method="get" name="details">
<table border="0">
<tr valign="top">
<td>View Account Details:</td>
<td align="left">
<select id="listAccounts" name="listAccounts" size="1">
<option value="800002">800002 Savings</option>
<option value="800003">800003 Checking</option>
<option value="4539082039396288">4539082039396288 Credit ...
Observed: No hidden anti-CSRF token input field detected inside form.
```

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDATION & FIX GUIDANCE

1. Convert sensitive state-changing actions from HTTP GET to HTTP POST.
2. Include cryptographically random, unpredictable anti-CSRF tokens in all state-changing HTML forms.

3. Enforce 'SameSite=Lax' or 'SameSite=Strict' on session cookies.
4. Require re-authentication (current password) for critical account actions (e.g., password change, email change).

#28 **MEDIUM** security_headers ✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET Endpoint: http://demo.testfire.net/bank/main.jsp

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#29

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET

Endpoint: http://demo.testfire.net/bank/main.jsp

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#30

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET

Endpoint: http://demo.testfire.net/bank/main.jsp

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#31

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: http://demo.testfire.net/bank/main.jsp

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-length, content-type, date, server
```

REMEDATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#32

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: http://demo.testfire.net/bank/main.jsp

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/bank/main.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/bank/main.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

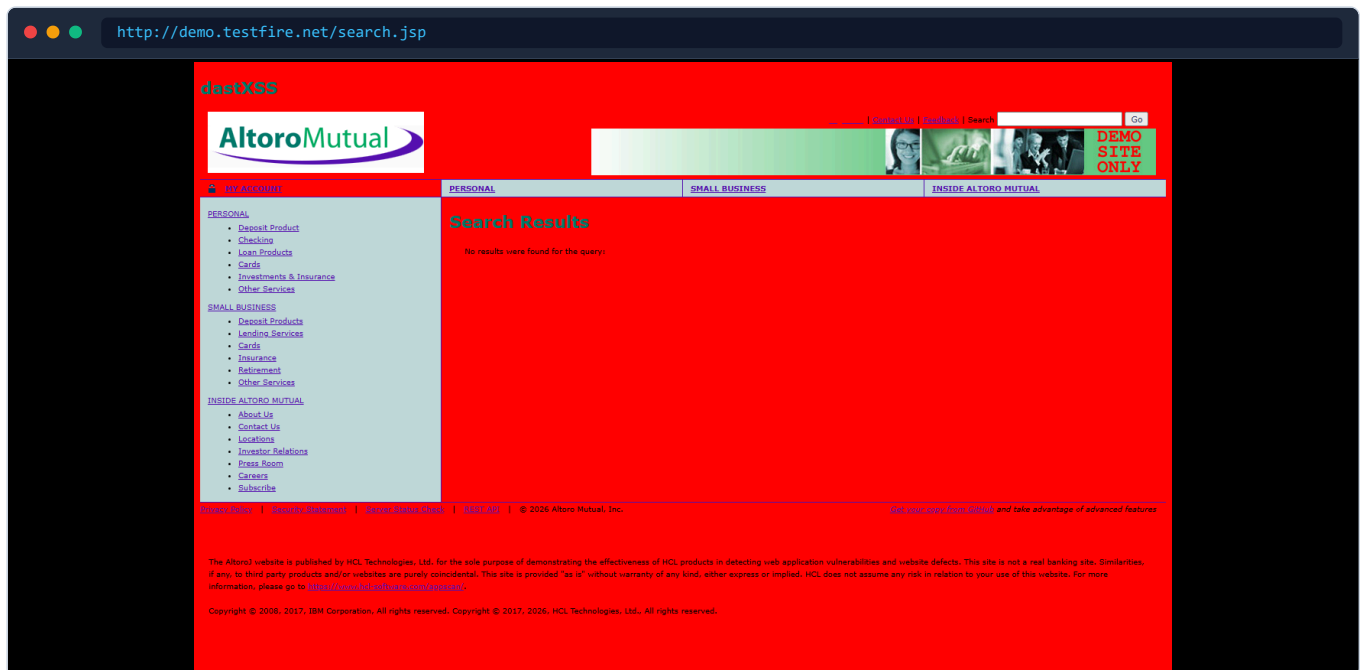
```
bash - reproduction command
```

1. Target Endpoint: GET `http://demo.testfire.net/search.jsp`
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroun...`'
4. Automated Reproduction Command:
`curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"`

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#34

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET

Endpoint: `http://demo.testfire.net/style.css`

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/style.css
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/style.css"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: accept-ranges, content-length, content-type, date, etag, last-modified, server
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#35

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET

Endpoint: `http://demo.testfire.net/style.css`

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/style.css
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/style.css"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: accept-ranges, content-length, content-type, date, etag, last-modified, server
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#36

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET

Endpoint: `http://demo.testfire.net/style.css`

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/style.css
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/style.css"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: accept-ranges, content-length, content-type, date, etag, last-modified, server
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#37

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: `http://demo.testfire.net/style.css`

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/style.css
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/style.css"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: accept-ranges, content-length, content-type, date, etag, last-modified, server
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#38

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: `http://demo.testfire.net/style.css`

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/style.css
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/style.css"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#39

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET

Endpoint: `http://demo.testfire.net/index.jsp`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#40

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET

Endpoint: `http://demo.testfire.net/index.jsp`

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#41

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET

Endpoint: `http://demo.testfire.net/index.jsp`

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#42

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET

Endpoint: http://demo.testfire.net/index.jsp

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#43

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: http://demo.testfire.net/index.jsp

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#44

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: `http://demo.testfire.net/index.jsp`

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...
```

```
4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

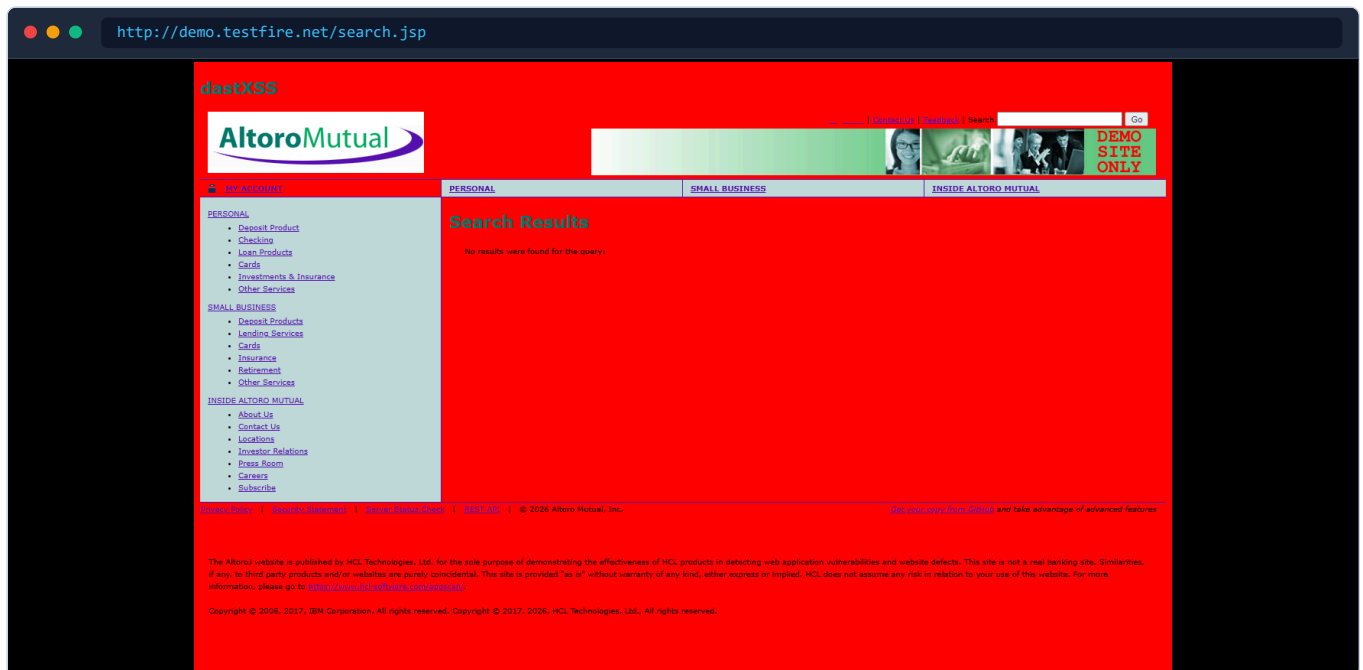
```
bash - reproduction command
```

1. Target Endpoint: GET `http://demo.testfire.net/search.jsp`
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroun...`'
4. Automated Reproduction Command:
`curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"`

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#46

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET Endpoint: `http://demo.testfire.net/logout.jsp`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/logout.jsp
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/logout.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#47

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET Endpoint: `http://demo.testfire.net/logout.jsp`

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/logout.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/logout.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#48

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET Endpoint: `http://demo.testfire.net/logout.jsp`

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/logout.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/logout.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#49

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET Endpoint: `http://demo.testfire.net/logout.jsp`

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/logout.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/logout.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#50

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: http://demo.testfire.net/logout.jsp

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/logout.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/logout.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#51

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: http://demo.testfire.net/logout.jsp

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/logout.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/logout.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#52 **HIGH** XSS **✓ Confirmed True Positive**

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

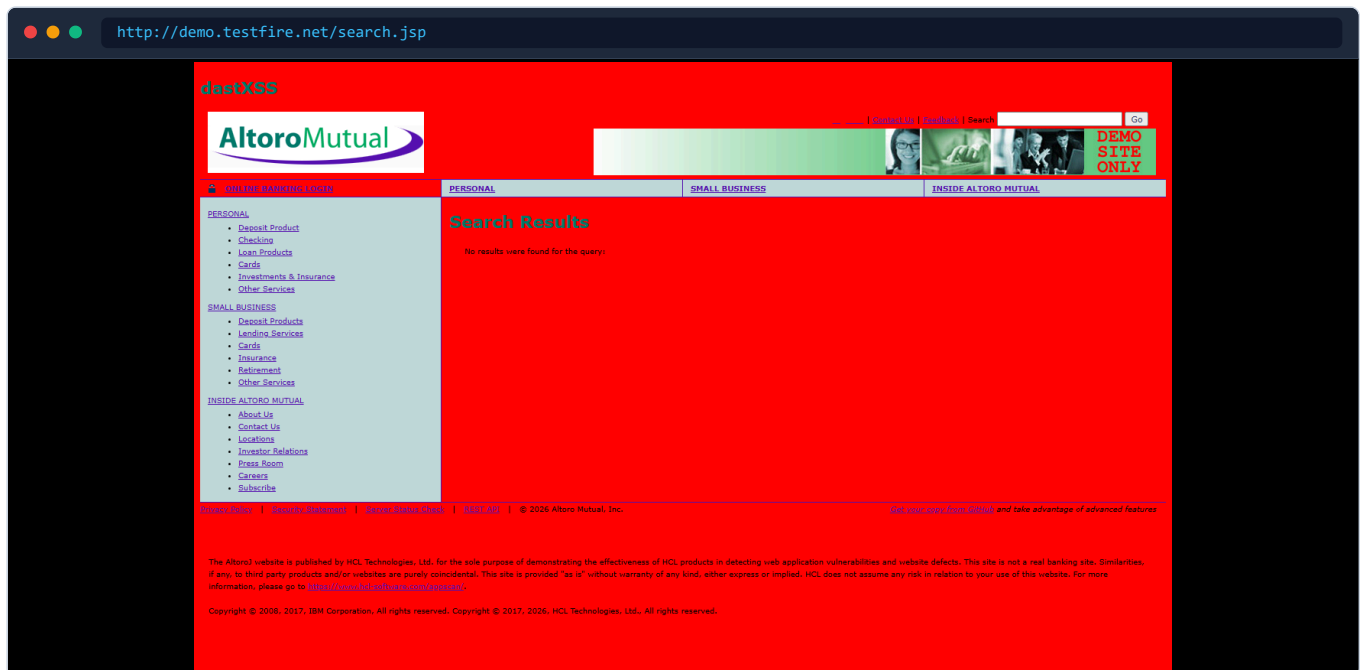
1. Target Endpoint: GET http://demo.testfire.net/search.jsp
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '<script>document.body.style.backgroun...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#53

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET

Endpoint: `http://demo.testfire.net/index.jsp`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#54

MEDIUM

html_injection

✓ Confirmed True Positive

HTML Injection in Parameter 'content'

GET

Endpoint: `http://demo.testfire.net/index.jsp` | Parameter: `content`

VULNERABILITY OVERVIEW & IMPACT

Parameter 'content' reflects user-supplied HTML tags directly into the web page without proper HTML entity encoding, allowing attackers to modify visual layout, deface pages, or perform phishing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
2. Vulnerable Parameter: 'content'
3. Exploit Payload / Trigger: DOM / HTML Traffic Evidence:
Injected HTML Payload: <h1>HTML_INJ_TEST</h1>
Un...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp?content=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

```
DOM / HTML Traffic Evidence:
Injected HTML Payload: <h1>HTML_INJ_TEST</h1>
Unencoded Reflection: Matched rendered markup '<h1>HTML_INJ_TEST</h1>'
Technique: Heading tag injection
```

REMEDIATION & FIX GUIDANCE

Contextually HTML entity encode all untrusted inputs before rendering them in the document.

#55

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET

Endpoint: http://demo.testfire.net/index.jsp

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#56

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET

Endpoint: http://demo.testfire.net/index.jsp

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#57

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET

Endpoint: <http://demo.testfire.net/index.jsp>

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#58

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: <http://demo.testfire.net/index.jsp>

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#59

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: `http://demo.testfire.net/index.jsp`

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/index.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/index.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#60

HIGH

dom_xss

✓ Confirmed True Positive

DOM-Based Cross-Site Scripting (DOM XSS) in 'content'

GET Endpoint: [http://demo.testfire.net/index.jsp?](http://demo.testfire.net/index.jsp?content=)`content="";document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>');//` | Parameter: `content`

VULNERABILITY OVERVIEW & IMPACT

Parameter or URL fragment flows into an unsafe client-side DOM sink without sanitization.

STEP-BY-STEP REPRODUCTION GUIDE

`bash - reproduction command`

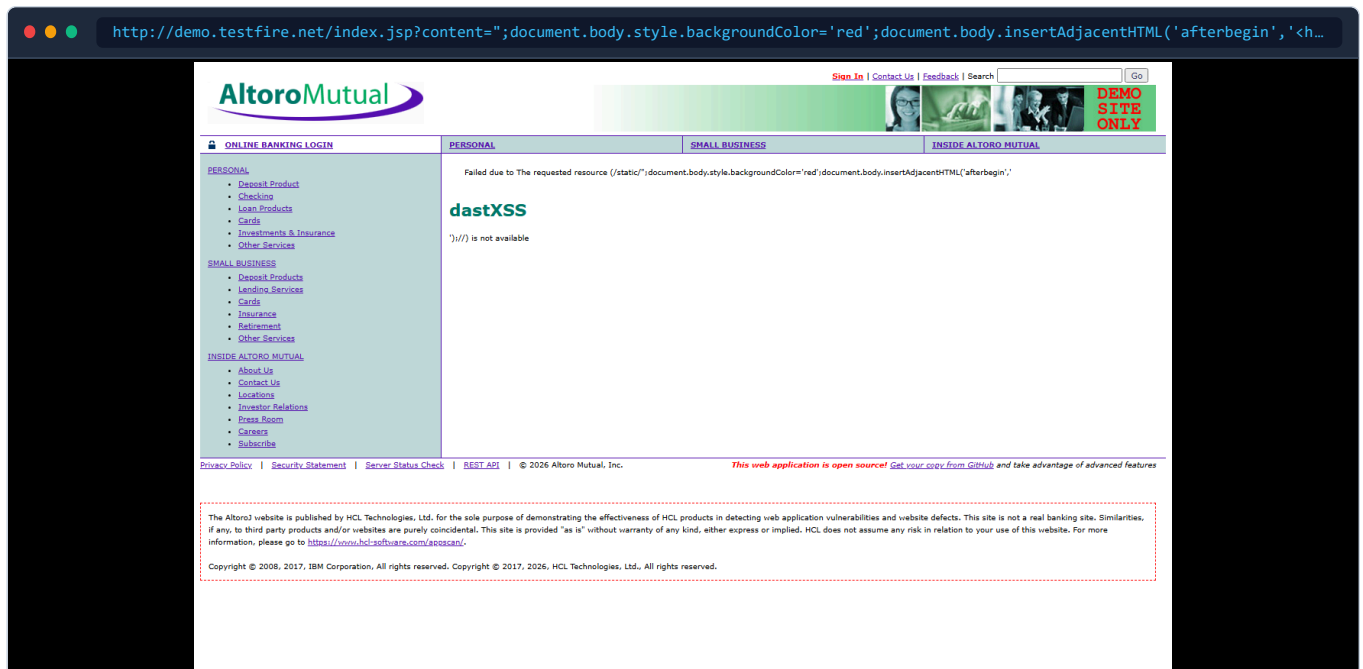
```
1. Target Endpoint: GET http://demo.testfire.net/index.jsp?content="";document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>');//
2. Vulnerable Parameter: 'content'
3. Exploit Payload / Trigger: Live DOM XSS confirmed in browser. Injected vector executed in client-side DO...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/index.jsp?content="";document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>');//&content=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

Live DOM XSS confirmed in browser. Injected vector executed in client-side DOM sink.
Target URL: [http://demo.testfire.net/index.jsp?content="";document.body.style.backgroundColor='red';document.body.insertAdjacentHTML\('afterbegin','<h1>dastXSS</h1>'\);//](http://demo.testfire.net/index.jsp?content=)
Payload: `"";document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>');//`

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDATION & FIX GUIDANCE

Avoid passing untrusted URL parameters or location hashes to `innerHTML`/`document.write`. Use `textContent` or `DOMPurify`.

#61 **HIGH** XSS **✓ Confirmed True Positive**

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

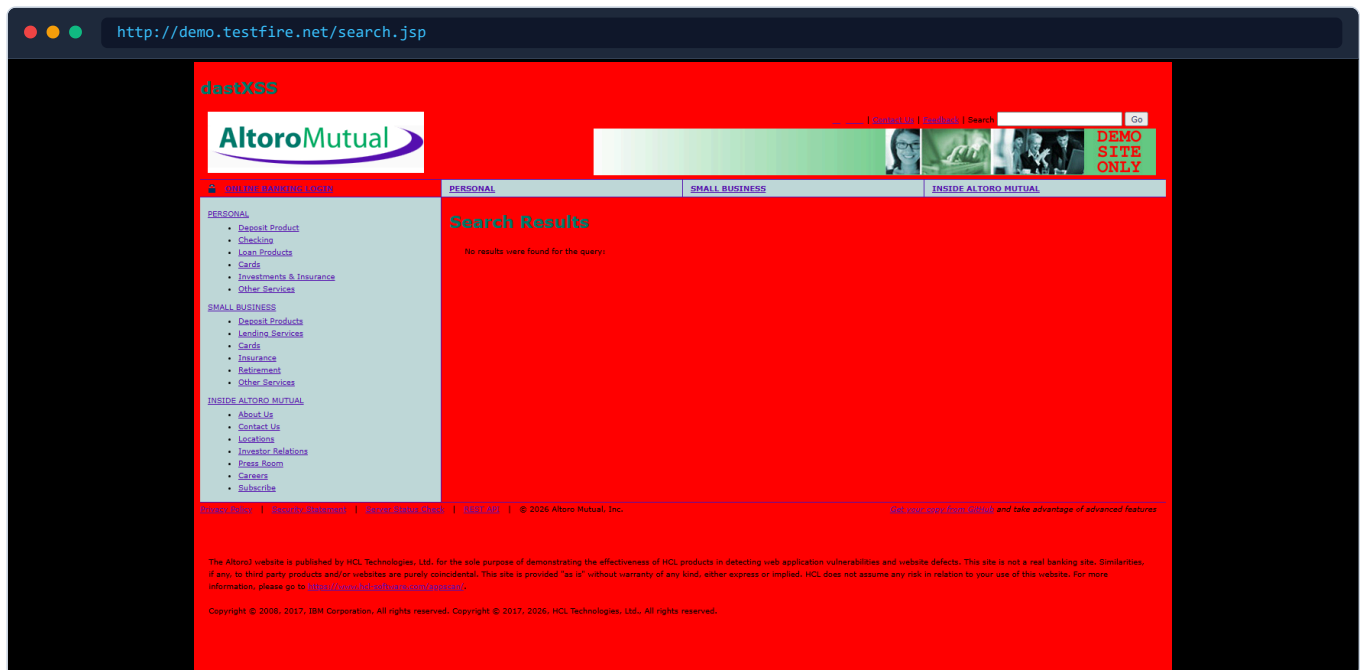
1. Target Endpoint: GET http://demo.testfire.net/search.jsp
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '<script>document.body.style.backgroun...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#62

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

POST

Endpoint: `http://demo.testfire.net/sendFeedback`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X POST "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#63

MEDIUM

html_injection

✓ Confirmed True Positive

HTML Injection in Parameter 'email_addr'

POST

Endpoint: `http://demo.testfire.net/sendFeedback` | Parameter: `email_addr`

VULNERABILITY OVERVIEW & IMPACT

Parameter 'email_addr' reflects user-supplied HTML tags directly into the web page without proper HTML entity encoding, allowing attackers to modify visual layout, deface pages, or perform phishing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
2. Vulnerable Parameter: 'email_addr'
3. Exploit Payload / Trigger: DOM / HTML Traffic Evidence:
Injected HTML Payload: <iframe src="about:blank"...

4. Automated Reproduction Command:
curl -i -k -X POST --data "email_addr=PAYLOAD" "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
DOM / HTML Traffic Evidence:
Injected HTML Payload: <iframe src="about:blank" height="0" width="0"></iframe>
Unencoded Reflection: Matched rendered markup '<iframe src="about:blank"'
Technique: iFrame tag injection
```

REMEDIATION & FIX GUIDANCE

Contextually HTML entity encode all untrusted inputs before rendering them in the document.

#64

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

POST

Endpoint: <http://demo.testfire.net/sendFeedback>

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X POST "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 405
Observed Headers: connection, content-language, content-length, content-type, date, server
```

REMEDATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#65

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

POST

Endpoint: <http://demo.testfire.net/sendFeedback>

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
curl -i -k -X POST "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 405
Observed Headers: connection, content-language, content-length, content-type, date, server
```

REMEDATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#66

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

POST

Endpoint: <http://demo.testfire.net/sendFeedback>

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
curl -i -k -X POST "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 405
Observed Headers: connection, content-language, content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#67

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

POST

Endpoint: <http://demo.testfire.net/sendFeedback>

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X POST "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 405
Observed Headers: connection, content-language, content-length, content-type, date, server
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#68

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

POST

Endpoint: `http://demo.testfire.net/sendFeedback`

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
  curl -i -k -X POST "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 405
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

#69

HIGH

ssii

✓ Confirmed True Positive

Server-Side Includes (SSI) Injection in Parameter 'cfile'

POST

Endpoint: `http://demo.testfire.net/sendFeedback` | Parameter: `cfile`

VULNERABILITY OVERVIEW & IMPACT

Parameter 'cfile' is vulnerable to SSI Injection. The web server evaluated the injected SSI directive prior to serving the HTML response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

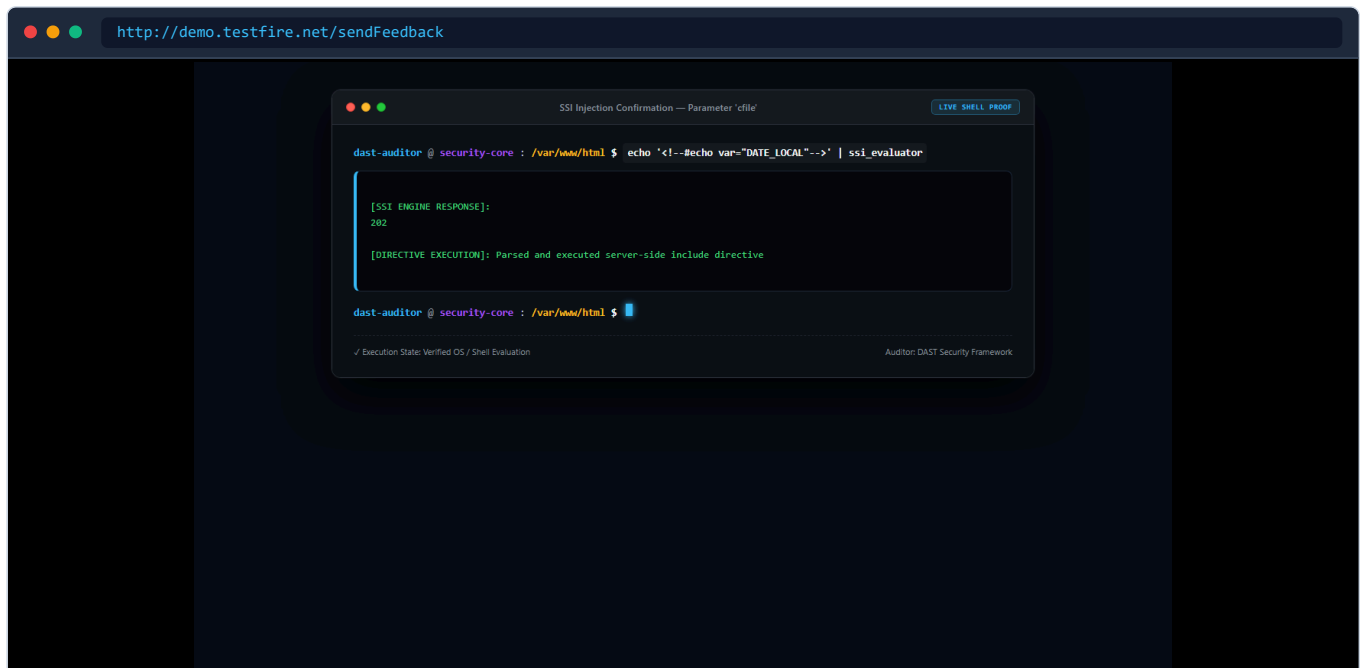
1. Target Endpoint: POST http://demo.testfire.net/sendFeedback
2. Vulnerable Parameter: 'cfile'
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
   Injected SSI Directive: <!--#echo var="DATE_LOCAL"-->
   ...

4. Automated Reproduction Command:
   curl -i -k -X POST --data "cfile=PAYLOAD" "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Injected SSI Directive: <!--#echo var="DATE_LOCAL"-->
Evaluated Output: Matched token '202'
Technique: SSI Date directive
```

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDATION & FIX GUIDANCE

Disable Server-Side Includes (SSI) execution in the web server configuration or sanitize HTML comment syntax.

#70

HIGH

stored_xss

✓ Confirmed True Positive

Stored Cross-Site Scripting (XSS) in Form Field 'name'

POST

Endpoint: `http://demo.testfire.net/sendFeedback` | Parameter: `name`

VULNERABILITY OVERVIEW & IMPACT

Form field 'name' stores arbitrary HTML/JS markup and renders it unencoded.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

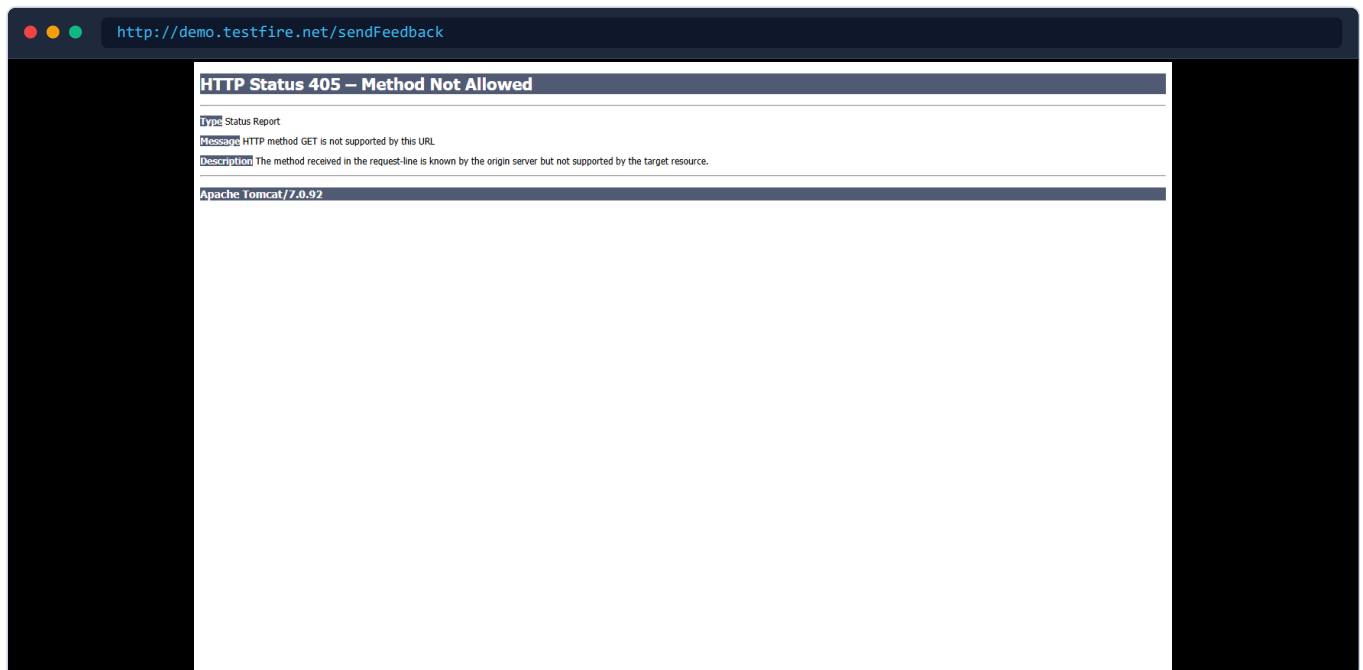
1. Target Endpoint: POST `http://demo.testfire.net/sendFeedback`
2. Vulnerable Parameter: 'name'
3. Exploit Payload / Trigger: Stored XSS confirmed. Injected payload '`<script>document.body.style.backgroun...`'
4. Automated Reproduction Command:

```
curl -i -k -X POST --data "name=PAYLOAD" "http://demo.testfire.net/sendFeedback"
```

TECHNICAL PROOF & RAW EVIDENCE

Stored XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' persisted in backend and rendered without encoding in subsequent page retrieval.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (HTML entity encoding) and sanitize storage inputs.

#71 HIGH XSS ✓ Confirmed True Positive

Reflected Cross-Site Scripting (XSS) in Form Field 'name'

POST Endpoint: `http://demo.testfire.net/sendFeedback` | Parameter: `name`

VULNERABILITY OVERVIEW & IMPACT

Form field 'name' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

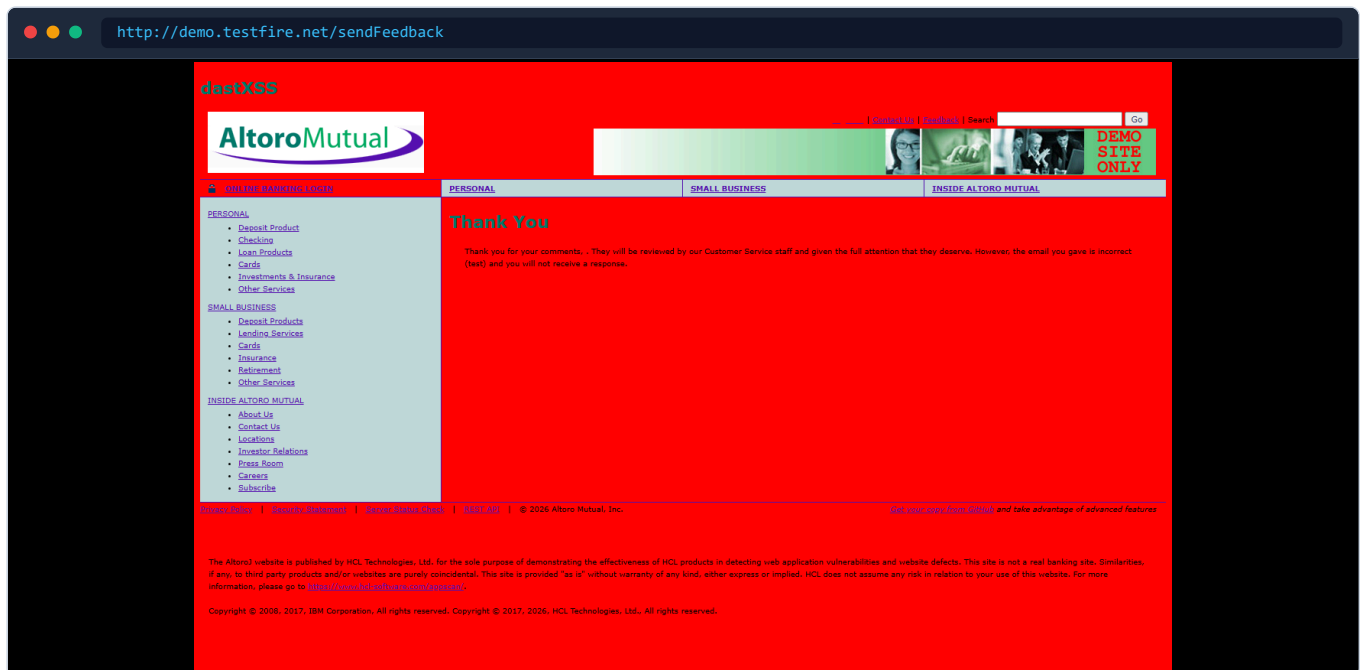
bash — reproduction command

1. Target Endpoint: POST `http://demo.testfire.net/sendFeedback`
2. Vulnerable Parameter: 'name'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload `'<script>document.body.style.backgroun...`
4. Automated Reproduction Command:
`curl -i -k -X POST --data "name=PAYLOAD" "http://demo.testfire.net/sendFeedback"`

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload `'<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>'` executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#72

MEDIUM

clickjacking

✓ Confirmed True Positive

Missing Clickjacking Defensive Framing Protections

GET Endpoint: `http://demo.testfire.net/feedback.jsp`

VULNERABILITY OVERVIEW & IMPACT

The page lacks both the X-Frame-Options header and CSP frame-ancestors directive. An attacker can frame this target within a transparent <iframe> on a malicious domain to trick authenticated users into clicking sensitive UI buttons (Clickjacking).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ance...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Response Header Evidence:
X-Frame-Options Header: Missing
CSP frame-ancestors Directive: Missing
```

REMEDIATION & FIX GUIDANCE

Set 'X-Frame-Options: SAMEORIGIN' or 'Content-Security-Policy: frame-ancestors 'self''.

#73

MEDIUM

csrf

✓ Confirmed True Positive

Missing Anti-CSRF Token in State-Changing Form

POST

Endpoint: `http://demo.testfire.net/feedback.jsp`

VULNERABILITY OVERVIEW & IMPACT

The form uses HTTP POST to perform sensitive state-changing operations without including a synchronized anti-CSRF token. If user sessions rely on ambient credentials (cookies), an external attacker can induce victim browsers to perform unauthorized actions.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

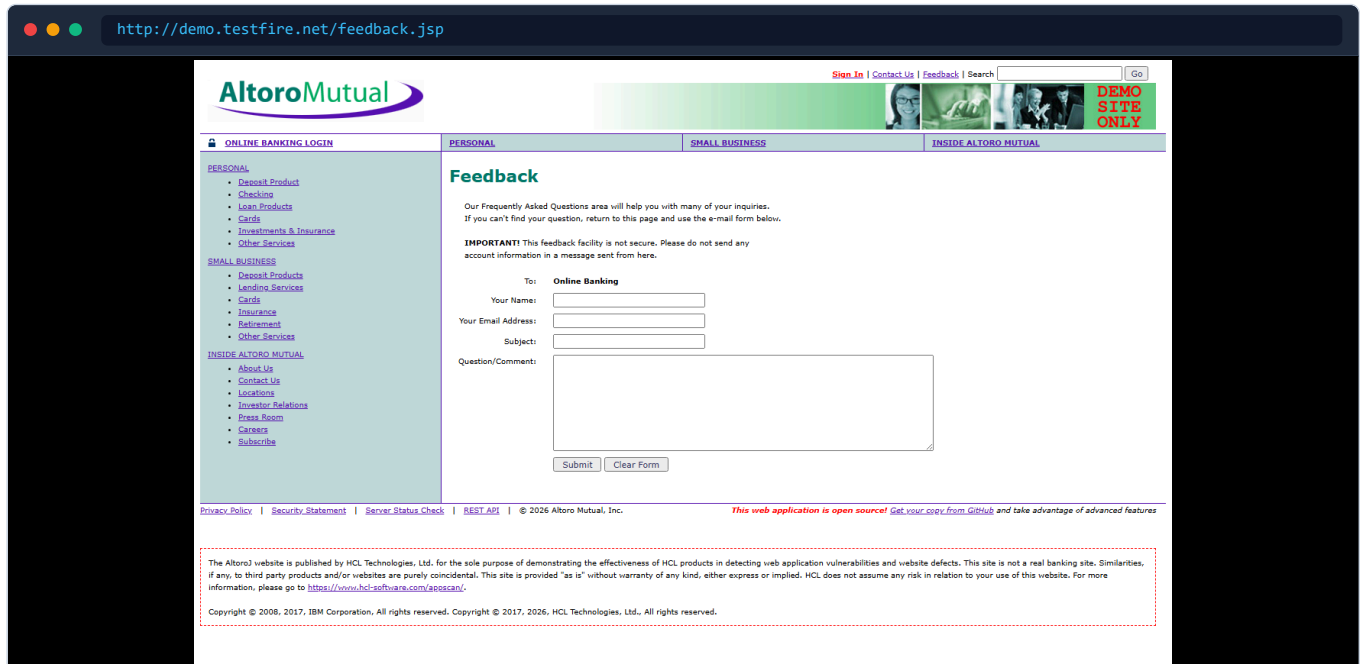
```
1. Target Endpoint: POST http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: DOM Form Evidence:
Form Method: POST
Form Action: sendFeedback
Input Fields: ...

4. Automated Reproduction Command:
curl -i -k -X POST "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
DOM Form Evidence:
Form Method: POST
Form Action: sendFeedback
Input Fields: cfile, name, email_addr, subject, comments, submit, reset
Form HTML Snippet:
<form action="sendFeedback" method="post" name="cmt">
<!-- Dave- Hard code this into the final script - Possible security problem.
      Re-generated every Tuesday and old files are saved to .bak format at L:\backup\website\oldfiles    --->
<input name="cfile" type="hidden" value="comments.txt"/>
<table border="0">
<tr>
<td align="right">To:</td>
<t...
Observed: No hidden anti-CSRF token input field detected inside form.
```

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

1. Convert sensitive state-changing actions from HTTP GET to HTTP POST.
2. Include cryptographically random, unpredictable anti-CSRF tokens in all state-changing HTML forms.

3. Enforce 'SameSite=Lax' or 'SameSite=Strict' on session cookies.
4. Require re-authentication (current password) for critical account actions (e.g., password change, email change).

#74 **MEDIUM** security_headers ✓ Confirmed True Positive

Missing Security Header: Content-Security-Policy

GET Endpoint: <http://demo.testfire.net/feedback.jsp>

VULNERABILITY OVERVIEW & IMPACT

Protects against Cross-Site Scripting (XSS), data injection, and clickjacking attacks.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Content-Security-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Define and enforce a strict Content-Security-Policy (CSP) restricting trusted sources.

#75

MEDIUM

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Frame-Options

GET Endpoint: `http://demo.testfire.net/feedback.jsp`

VULNERABILITY OVERVIEW & IMPACT

Defends against UI redress attacks (Clickjacking) by disallowing framing.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
S...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Frame-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Frame-Options to DENY or SAMEORIGIN.

#76

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: X-Content-Type-Options

GET Endpoint: `http://demo.testfire.net/feedback.jsp`

VULNERABILITY OVERVIEW & IMPACT

Prevents MIME-type sniffing which can lead to script execution via non-executable files.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

1. Target Endpoint: GET http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Op...

4. Automated Reproduction Command:
  curl -i -k -X GET "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: X-Content-Type-Options
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Set X-Content-Type-Options to 'nosniff'.

#77

LOW

security_headers

✓ Confirmed True Positive

Missing Security Header: Referrer-Policy

GET

Endpoint: http://demo.testfire.net/feedback.jsp

VULNERABILITY OVERVIEW & IMPACT

Protects sensitive URLs and query parameters from leaking via the HTTP Referer header.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
S...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Missing Recommended Security Header: Referrer-Policy
Status Code: 200
Observed Headers: content-type, date, server, transfer-encoding
```

REMEDIATION & FIX GUIDANCE

Configure Referrer-Policy to 'strict-origin-when-cross-origin' or 'no-referrer'.

#78

LOW

security_headers

✓ Confirmed True Positive

Information Disclosure: Server Header

GET

Endpoint: http://demo.testfire.net/feedback.jsp

VULNERABILITY OVERVIEW & IMPACT

Web server vendor and version banner disclosure: 'Apache-Coyote/1.1' was returned in the server response.

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command
```

```
1. Target Endpoint: GET http://demo.testfire.net/feedback.jsp
3. Exploit Payload / Trigger: HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Cod...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/feedback.jsp"
```

TECHNICAL PROOF & RAW EVIDENCE

```
HTTP Traffic Evidence:
Disclosed Header: Server: Apache-Coyote/1.1
Status Code: 200
```

REMEDIATION & FIX GUIDANCE

Configure the web server or reverse proxy to strip or suppress the Server header.

Stored Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' stores arbitrary HTML/JS markup and renders it unencoded.

STEP-BY-STEP REPRODUCTION GUIDE

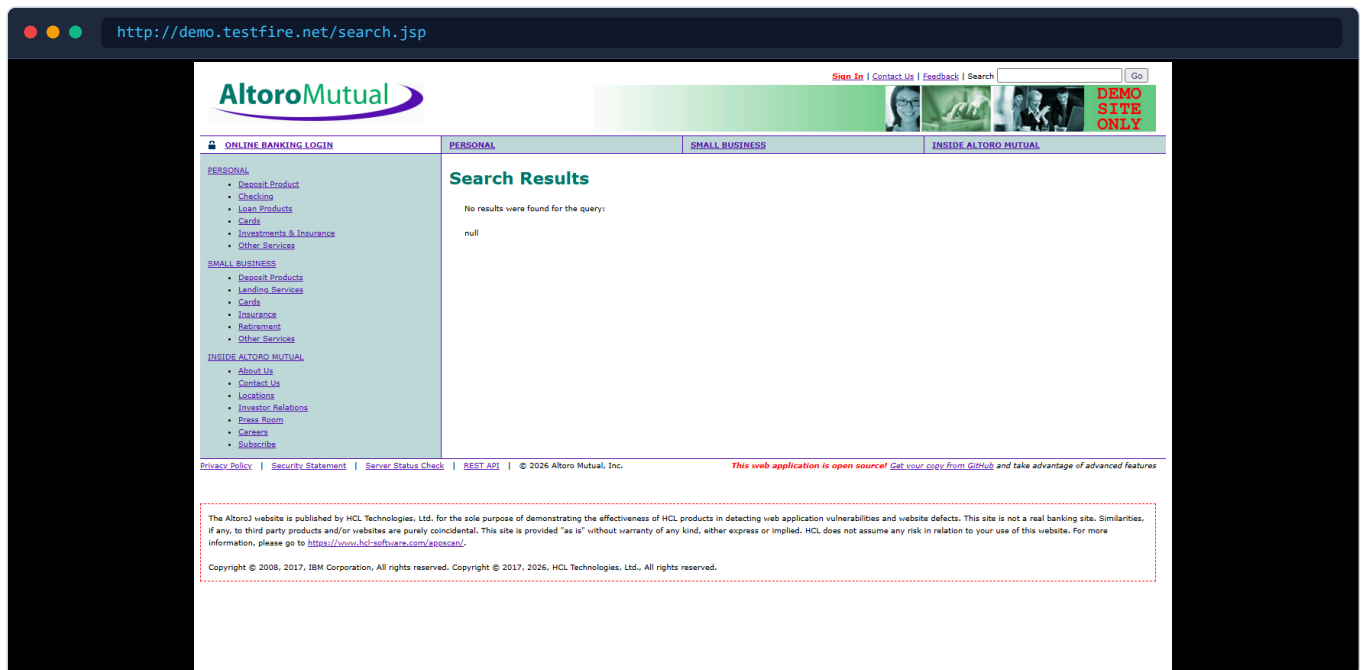
bash – reproduction command

1. Target Endpoint: GET `http://demo.testfire.net/search.jsp`
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Stored XSS confirmed. Injected payload '`<script>document.body.style.backgroun...`'
4. Automated Reproduction Command:
`curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"`

TECHNICAL PROOF & RAW EVIDENCE

Stored XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' persisted in backend and rendered without encoding in subsequent page retrieval.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (HTML entity encoding) and sanitize storage inputs.

#80 **HIGH** XSS **✓ Confirmed True Positive**

Reflected Cross-Site Scripting (XSS) in Form Field 'query'

GET Endpoint: `http://demo.testfire.net/search.jsp` | Parameter: `query`

VULNERABILITY OVERVIEW & IMPACT

Form field 'query' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

```
bash - reproduction command

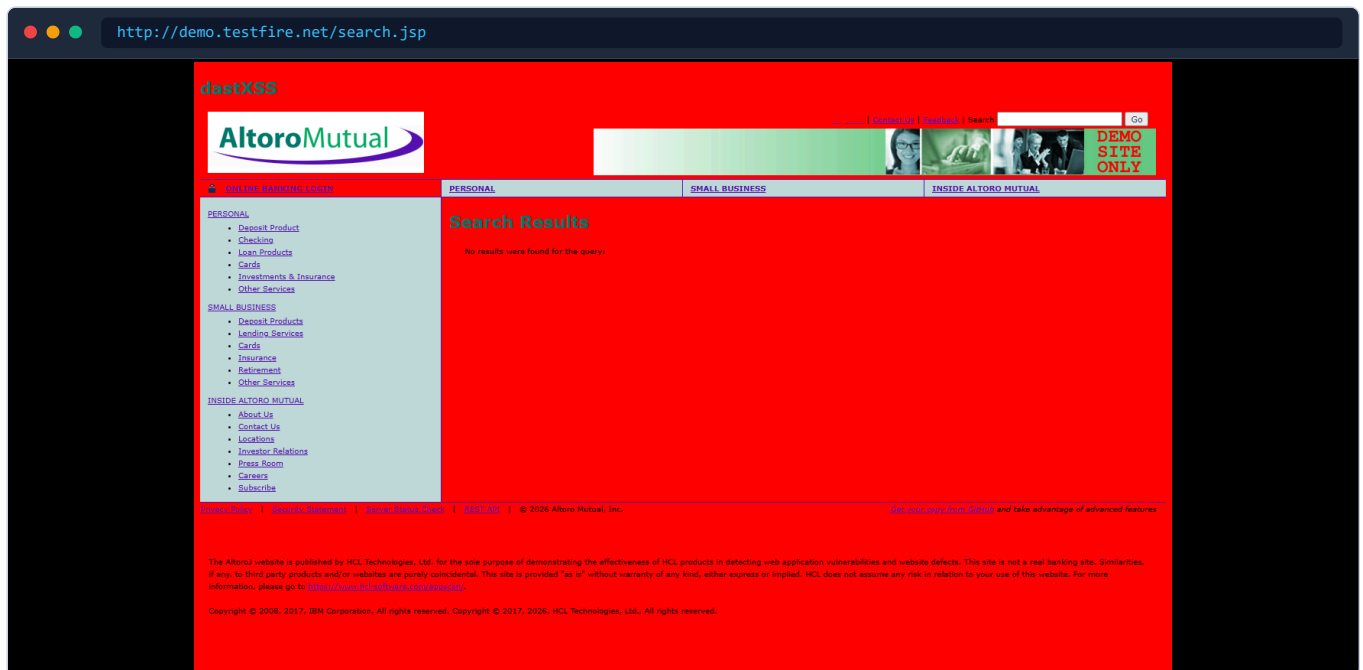
1. Target Endpoint: GET http://demo.testfire.net/search.jsp
2. Vulnerable Parameter: 'query'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload '<script>document.body.style.backgroun...

4. Automated Reproduction Command:
curl -i -k -X GET "http://demo.testfire.net/search.jsp?query=PAYLOAD"
```

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload '`<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>`' executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.

#81 **HIGH** XSS **✓ Confirmed True Positive**

Reflected Cross-Site Scripting (XSS) in Form Field 'name'

POST Endpoint: `http://demo.testfire.net/sendFeedback` | Parameter: `name`

VULNERABILITY OVERVIEW & IMPACT

Form field 'name' is vulnerable to reflected Cross-Site Scripting (XSS).

STEP-BY-STEP REPRODUCTION GUIDE

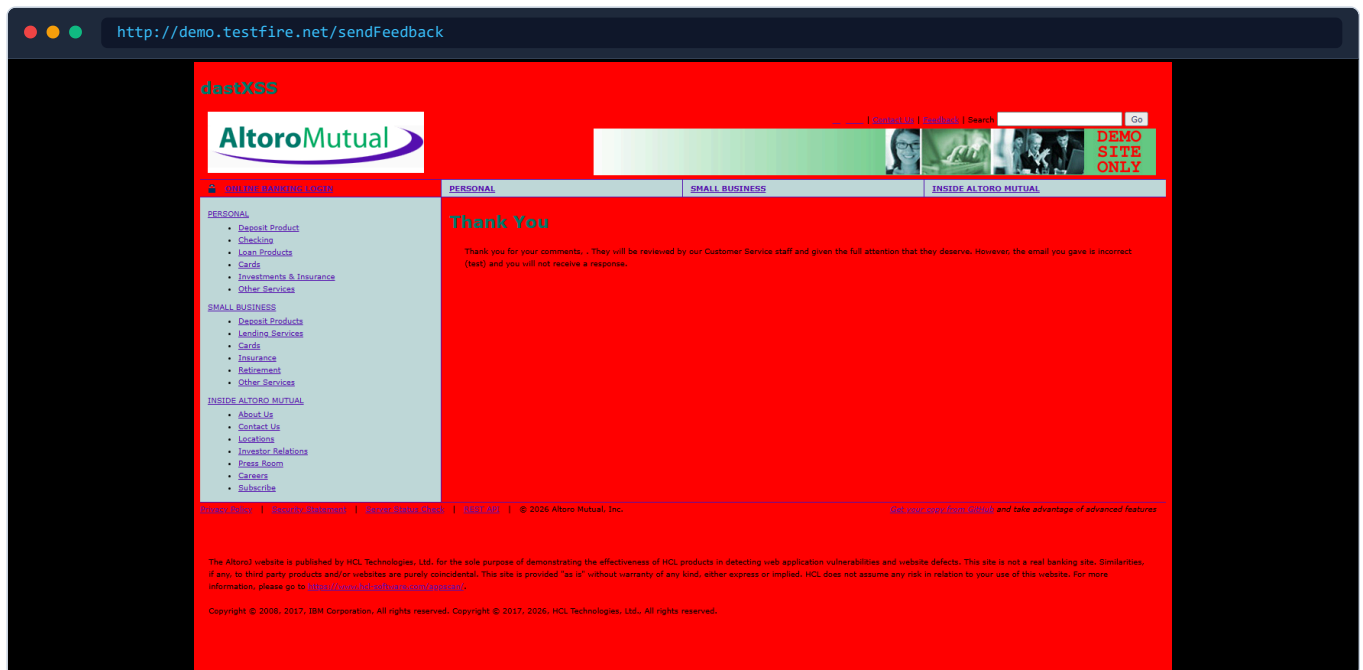
bash — reproduction command

1. Target Endpoint: POST `http://demo.testfire.net/sendFeedback`
2. Vulnerable Parameter: 'name'
3. Exploit Payload / Trigger: Visual XSS confirmed. Injected payload `'<script>document.body.style.backgroun...`
4. Automated Reproduction Command:
`curl -i -k -X POST --data "name=PAYLOAD" "http://demo.testfire.net/sendFeedback"`

TECHNICAL PROOF & RAW EVIDENCE

Visual XSS confirmed. Injected payload `'<script>document.body.style.backgroundColor='red';document.body.insertAdjacentHTML('afterbegin','<h1>dastXSS</h1>')</script>'` executed in DOM with visual indicators.

VISUAL SCREENSHOT PROOF OF EXECUTION



REMEDIATION & FIX GUIDANCE

Contextually encode all user-supplied output (e.g. HTML entity encoding) and enforce a strict CSP.